

A.H

Informe de Análisis de Vulnerabilidades

Resumen

Este informe documenta los resultados de un escaneo de vulnerabilidades realizado con Nessus Essentials sobre un Windows Server 2008 (IP: 10.0.2.4) desde una máquina Parrot con Nessus instalado (IP: 10.0.2.5).

Se documentarán tres de las cinco vulnerabilidades críticas encontradas, ya que las otras dos son faltas de soporte.

Las vulnerabilidades seleccionadas y documentadas en detalle son:

- MS11-004 — Vulnerability in Internet Information Services (IIS) FTP Service (RCE).
- CVE-2019-0708 — Microsoft Remote Desktop Services Remote Code Execution (BlueKeep).
- MS11-030 — Vulnerability in DNS resolution (RCE).

Se incluyen instrucciones paso a paso para aplicar parches y mitigaciones

Metodología

Herramientas y entorno:

- Nessus Essentials (ejecutado en Parrot OS) IP: 10.0.2.5.
- Windows Server 2008 (instancia de laboratorio) IP: 10.0.2.4.
- Conectividad configurada en red NAT entre las máquinas.

1. MS11-004 — Vulnerability in Internet Information Services (IIS) FTP Service

Resumen técnico:

MS11-004 es una actualización de seguridad de Microsoft que corrige una vulnerabilidad en el servicio FTP de Internet Information Services (IIS). La explotación permite la ejecución remota de código si un atacante remoto envía comandos FTP especialmente contruidos hacia un servidor IIS vulnerable.

Identificación en el escaneo:

Plugin detectado: 24989256 (uncredentialed check). El plugin marcó la existencia de un servicio FTP proporcionado por IIS con una versión vulnerable. En Nessus Essentials aparece como vulnerabilidad crítica (CVSS 9.8).

CVE(s) asociadas:

CVE-2010-3972

Impacto:

Ejecución remota de código (RCE) con privilegios del servicio. En un entorno real, un atacante podría tomar control del servidor, subir o modificar archivos, o pivotar hacia otros activos en la red.

Evidencia encontrada:

En la salida del plugin Nessus se observó la detección del servicio FTP de IIS y la correlación con la firma del plugin.

Táctica de remediación (paso a paso):

1) Evaluar si el servicio FTP es necesario. Si no lo es, deshabilitarlo temporalmente o eliminar el rol FTP en IIS:

- Abrir 'Server Manager' → Roles → Web Server (IIS) → Remove Role Services → desmarcar 'FTP Server'.

2) Aplicar el parche recomendado por Microsoft (MS11-004). Pasos:

- Descargar e instalar el boletín de seguridad desde el catálogo de Microsoft o a través de Windows Update / WSUS.

- Reiniciar el servicio IIS o, si es necesario, el equipo

- Desde PowerShell (ejecutar como administrador)

3) Verificación:

- Repetir el escaneo con Nessus y comprobar que ya no se reporta la vulnerabilidad.

- Comprobar que el puerto FTP ya no ofrece la versión vulnerable mediante nmap o una conexión FTP controlada.

Mitigación temporal (si no se puede parchear inmediatamente):

- Bloquear el puerto FTP (21) a nivel de firewall perimetral o firewall del host.

Referencias:

- Microsoft Security Bulletin MS11-004 (KB2489256).

- Plugin Tenable 24989256 / Documentación Nessus.

2. CVE-2019-0708 — Microsoft RDP Remote Code Execution (BlueKeep)

Resumen técnico:

CVE-2019-0708, conocido como 'BlueKeep', es una vulnerabilidad crítica en Remote Desktop Services (RDS) que permite la ejecución remota de código sin necesidad de autenticación previa. Afecta a varias versiones de Windows, incluyendo Windows Server 2008 si no se ha aplicado el parche correspondiente.

Identificación en el escaneo:

Plugin detectado: Microsoft RDP RCE (BlueKeep). En algunos casos Nessus realiza comprobaciones uncredentialed que indican la presencia de la vulnerabilidad o la exposición del servicio RDP; en otros se marca como 'unsupported' si la versión de OS impide confirmación completa.

Impacto:

Ejecución remota de código (RCE) con posibilidad de propagación entre sistemas, similar a vulnerabilidades explotadas masivamente en el pasado. Control completo del sistema y acceso a datos sensibles son posibles si se explota con éxito.

Evidencia encontrada:

Nessus reportó un hallazgo asociado a BlueKeep en la comprobación no autenticada. También se observó la nota 'plugin: unsupported windows os (remote)' en ciertos checks, lo que indica que el plugin no pudo garantizar una comprobación completa para esa plataforma específica; aun así la detección inicial sugiere exposición del servicio RDP.

Táctica de remediación (paso a paso):

1) Aplicar parche de seguridad correspondiente de Microsoft. En sistemas afectados por BlueKeep, Microsoft publicó parches en mayo de 2019 y versiones posteriores; aplicar las actualizaciones por Windows Update o instalar los paquetes desde el Catálogo de Microsoft.

- Para Windows Server 2008, buscar el KB específico relacionado con CVE-2019-0708 y aplicarlo manualmente o hacerlo con Windows Update.

2) Si no es posible parchear de inmediato, deshabilitar Remote Desktop Services o restringir el acceso al puerto 3389 mediante:

- Bloqueo a nivel de firewall para direcciones externas: solo permitir conexiones desde IPs administradas.

- Configurar reglas en el cortafuegos de Windows para limitar el acceso.

3) Verificación:

- Ejecutar un nuevo escaneo Nessus y confirmar que la detección de BlueKeep ya no aparece.

- Comprobar desde Parrot que el puerto 3389 responde solo a hosts permitidos (nmap).

Referencias:

- Microsoft Security Advisory for CVE-2019-0708.

- Plugin Tenable / Documentación Nessus.

3. MS11-030 — Vulnerability in DNS resolution

Resumen técnico:

MS11-030 describe una vulnerabilidad en la resolución DNS de Microsoft que podría permitir la ejecución remota de código mediante respuestas DNS manipuladas. Afecta a implementaciones de resolución de DNS en ciertas versiones de Windows Server, y su explotación puede permitir ejecución remota bajo el contexto del servicio de resolución.

Identificación en el escaneo:

Plugin detectado: 2509553 (remote check). El plugin marcó condiciones en el servicio de resolución DNS que coinciden con la firma de vulnerabilidad reportada por MS11-030.

CVE(s) asociadas:

CVE-2011-0657

Impacto:

Ejecución remota de código con privilegios del servicio DNS. Compromiso del servidor DNS puede permitir envenenamiento de cache, redirección de tráfico y pivoting en la red interna.

Evidencia encontrada:

El plugin Nessus detectó la huella asociada al servicio DNS vulnerable en el host.

Táctica de remediación (paso a paso):

1) Aplicar el parche de seguridad MS11-030 (KB2509553) mediante Windows Update, WSUS o descargando manualmente el paquete desde el Catálogo de Microsoft.

2) Reiniciar el servicio DNS o el equipo según las instrucciones del boletín.

3) Verificación:

- Re-scan con Nessus para comprobar que el plugin 2509553 ya no reporta el problema.
- Validar resolución DNS con herramientas como **nslookup**.

Referencias:

- Microsoft Security Bulletin MS11-030 (KB2509553).

Plan de remediación y priorización

Prioridad y plan de acción propuesto:

- 1) Aplicar parches para BlueKeep (CVE-2019-0708) y para las vulnerabilidades MS11-004 y MS11-030. (Prioridad: Inmediata, P0).
- 2) Si no se puede parchear de inmediato, aplicar mitigaciones temporales: bloquear puertos necesarios y restringir accesos a redes de administración.
- 3) Plan a medio plazo: migración a versiones de Windows Server soportadas y revisión de la necesidad de exponer servicios directamente a la red.
- 4) Documentar y ejecutar pruebas de verificación posteriores al parcheo: re-scan completo y generación de un informe final con evidencias.

Capturas

Aquí se adjuntarán capturas para verificar que el ejercicio se ha realizado correctamente.

```
Administrador: C:\Windows\System32\cmd.exe
Respuesta desde 10.0.2.5: bytes=32 tiempo<1m TTL=64
Respuesta desde 10.0.2.5: bytes=32 tiempo<1m TTL=64
Respuesta desde 10.0.2.5: bytes=32 tiempo<1m TTL=64
Respuesta desde 10.0.2.5: bytes=32 tiempo<1m TTL=64

Estadísticas de ping para 10.0.2.5:
    Paquetes: enviados = 4, recibidos = 4, perdidos = 0
    (0% perdidos),
    Tiempos aproximados de ida y vuelta en milisegundos:
        Mínimo = 0ms, Máximo = 0ms, Media = 0ms

C:\Windows\system32>ip config
"ip" no se reconoce como un comando interno o externo,
programa o archivo por lotes ejecutable.

C:\Windows\system32>ipconfig

Configuración IP de Windows

Adaptador de Ethernet Conexión de área local:

    Sufijo DNS específico para la conexión. . . : home
    Vínculo: dirección IPv6 local. . . . . : fe80::fdc5:e8db:d53:a417%11
    Dirección IPv4. . . . . : 10.0.2.4
    Máscara de subred . . . . . : 255.255.255.0
    Puerta de enlace predeterminada . . . . . : 10.0.2.1

C:\Windows\system32>netsh advfirewall set allprofiles state off
Aceptar

C:\Windows\system32>netsh advfirewall show allprofiles

Configuración de Perfil de dominio:
-----
Estado                                DESACTIVAR
Directiva de firewall                 BlockInbound,AllowOutbound
LocalFirewallRules                   N/A (sólo almacén de GPOs)
LocalConSecRules                     N/A (sólo almacén de GPOs)
InboundUserNotification              Deshabilitar
RemoteManagement                    Deshabilitar
UnicastResponseToMulticast           Habilitar
```

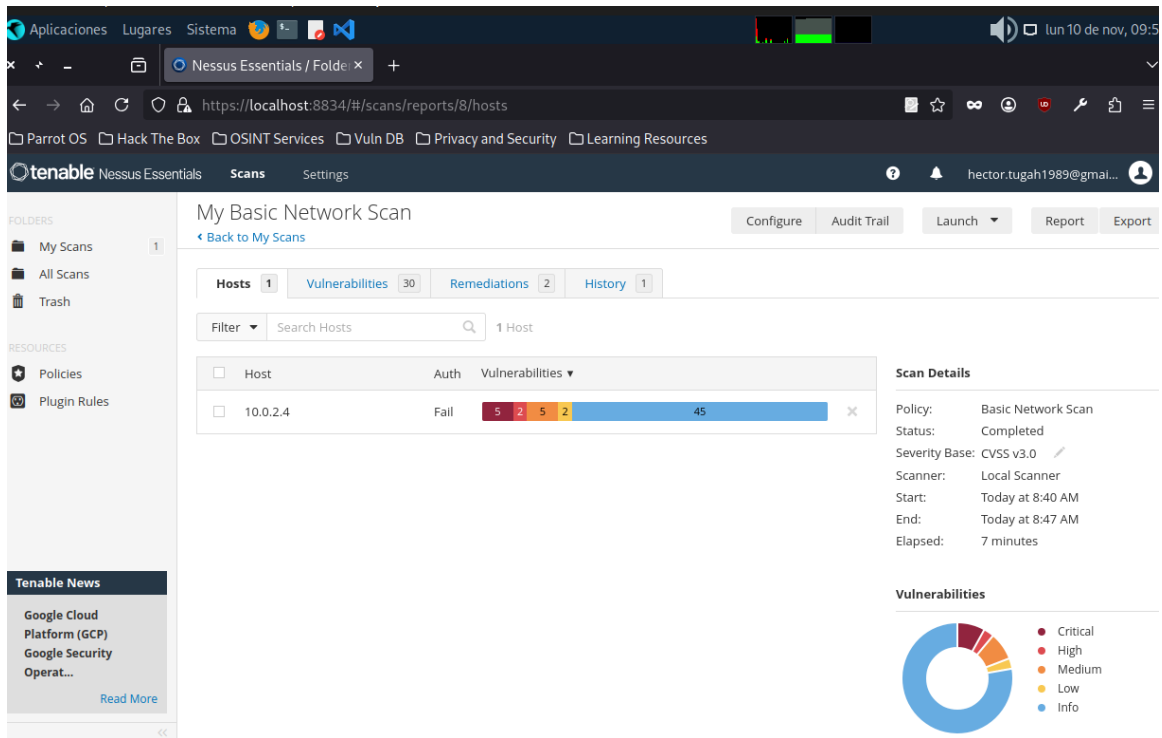
Ping a Parrot y desactivación de firewall (si no se podía hacer ping de parrot a windows).

```
$ping -c 4 10.0.2.4
PING 10.0.2.4 (10.0.2.4) 56(84) bytes of data.
64 bytes from 10.0.2.4: icmp_seq=1 ttl=128 time=0.418 ms
64 bytes from 10.0.2.4: icmp_seq=2 ttl=128 time=0.227 ms
64 bytes from 10.0.2.4: icmp_seq=3 ttl=128 time=0.226 ms
64 bytes from 10.0.2.4: icmp_seq=4 ttl=128 time=0.268 ms

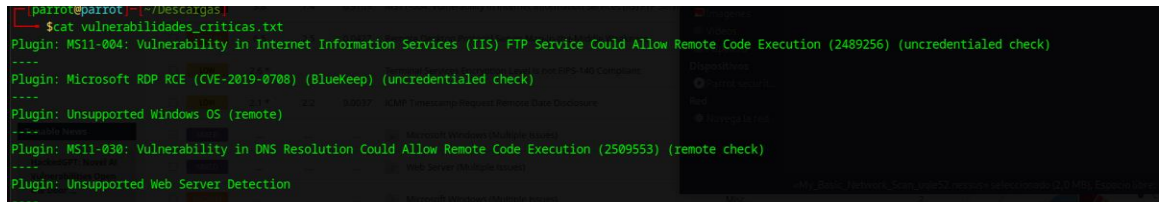
--- 10.0.2.4 ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3035ms
rtt min/avg/max/mdev = 0.226/0.284/0.418/0.078 ms
[parrot@parrot]-[~]
$sudo nmap -Pn -p 135,139,445,3389 10.0.2.4
[sudo] contraseña para parrot:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-10 09:31 CET
Nmap scan report for 10.0.2.4
Host is up (0.00026s latency).

PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
3389/tcp   open  ms-wbt-server
MAC Address: 08:00:27:32:42:48 (Oracle VirtualBox virtual NIC)
```

Ping de Parrot a Windows y NMAP para confirmar que los puertos necesarios están abiertos.



Escáner realizado con Nessus.



Pensaba que los mensajes de unsupported eran errores al encontrar las vulnerabilidades así que hice exporté el análisis y separé las vulnerabilidades críticas en un .txt para poder identificarlas bien y buscar una solución.